

Warsaw, December 20, 2023

Decision

DKN.5131.32.2023

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended) in connection with Articles 7, 60, Article 102 § 1 point 1 and § 3 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781) and Article 57 § 1 letter a) and letter h), Article 58 § 2 letter d), e) and letter i), Article 83 § 1 and 2, Article 83 § 4 letter a) in connection with Article 24 § 1, Article 25 § 1, Article 32 § 1 and 2, and Article 34 § 2 and 4 in connection with Article 33 § 3, as well as Article 83 § 5 letter a) in connection with Article 5 § 1 letter a) and f), Article 5 § 2, Article 6 § 1 and Article 9 § 1 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 04.05.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by the Minister of Health (Warsaw, Miodowa Street 15), the President of the Personal Data Protection Office, stating the violation by the Minister of Health (Warsaw, Miodowa Street 15) of the provisions:

a) Article 6 § 1 and Article 9 § 1 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 04.05.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as "Regulation 2016/679", consisting of unlawful processing of personal data, including data of a special category, by obtaining them from the Electronic Platform [...], referred to in Article 7 § 1 of the Act of April 28, 2011, on the Information System in Health Care (Journal of Laws of 2023, item 2465), and publishing them on the social platform X (formerly Twitter) without legal basis, which resulted in a violation of the principles of lawfulness, fairness, and transparency, as defined in Article 5 § 1 letter a) of Regulation 2016/679, the principle of integrity and confidentiality, expressed in Article 5 § 1 letter f) of Regulation 2016/679, and the principle of accountability, referred to in Article 5 § 2 of Regulation 2016/679;

b) Article 24 § 1, Article 25 § 1, and Article 32 § 1 and 2 of Regulation 2016/679, consisting of the failure to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of processing data using the Electronic Platform [...], referred to in Article 7 § 1 of the Act of April 28, 2011, on the Information System in Health Care (Journal of Laws of 2023, item 2465), including their protection against accidental loss, destruction, or damage and disclosure to unauthorized persons, which resulted in a violation of the principles of integrity and confidentiality (Article 5 § 1 letter f) of Regulation 2016/679) and the principle of accountability (Article 5 § 2 of Regulation 2016/679);

c) Article 34 § 2 in connection with Article 33 § 3 of Regulation 2016/679, consisting of the failure to provide the person whose data was violated in the manner specified in point a) with the information referred to in Article 33 § 3 letters c) and d) of Regulation 2016/679, namely a description of the possible consequences of the personal data breach and a description of the measures taken or proposed by the controller to address the breach, including measures to minimize its potential negative effects;

1) imposes on the Minister of Health (Warsaw, Miodowa Street 15) for the violation of Article 5 § 1 letter a) and f), Article 5 § 2, Article 6 § 1, Article 9 § 1, Article 25 § 1, Article 32 § 1 and 2, and Article 34 § 2 in connection with Article 33 § 3 of Regulation 2016/679 an administrative fine in the amount of 100,000 PLN (in words: one hundred thousand zlotys);

2) orders the Minister of Health (Warsaw, Miodowa Street 15) to implement – within 30 days from the date of delivery of this decision – appropriate technical and organizational measures to minimize the

risk associated with the processing of personal data using the Electronic Platform [...], referred to in Article 7 § 1 of the Act of April 28, 2011, on the Information System in Health Care (Journal of Laws of 2023, item 2465), particularly arising from accidental or unlawful destruction, loss, modification, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed, after conducting a risk analysis, taking into account the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, and the risk of infringement of the rights or freedoms of natural persons;

3) orders the Minister of Health (Warsaw, Miodowa Street 15) to notify – within 3 days from the date of delivery of this decision – the person whose data was disclosed on the social platform X (formerly Twitter) about the breach of personal data protection in order to provide them with information. defined in Article 34(2) in connection with Article 33(3)(c) and (d) of Regulation 2016/679, i.e.:

- a description of the possible consequences of a breach of personal data protection;
- a description of the measures taken or proposed by the administrator to remedy the breach, including measures to minimize its potential negative effects.

Justification

The Minister of Health (hereinafter also referred to as the Administrator) on (...) August 2023 published a post on the social media platform X (formerly Twitter) containing information about a doctor who issued a prescription "pro auctore" for a drug from the group of psychotropic and analgesic medications, which is subject to the regulation of the Minister of Health dated July 12, 2023, amending the regulation on narcotic drugs, psychotropic substances, precursors of category 1, and preparations containing these substances or compounds (Journal of Laws of 2023, item 1368). The post included the personal data of the doctor in the form of their name and surname, workplace, and information about the category of the medication for which the prescription was issued. In connection with the aforementioned event, on August 9, 2023, a preliminary notification of a breach of personal data protection was submitted to the President of the Personal Data Protection Office, hereinafter referred to as the President of UODO, by the Minister of Health, indicating that a breach of personal data protection occurred involving data processed using the Electronic Platform [...], referred to in Article 7(1) of the Act of April 28, 2011, on the information system in health care (Journal of Laws of 2023, item 2465), hereinafter also referred to as the "system [...]". In the notification, the Administrator confirmed that the Minister of Health obtained the personal data of the doctor from the system [...] through individuals authorized to use the aforementioned system. It was indicated that the Director of the [...] Division in the Ministry of Health, at the oral instruction of the Minister of Health, appointed an employee who decrypted in the system [...] the prescription containing the personal data of the doctor and subsequently provided the information contained therein to the Minister of Health.

On September 8, 2023, a supplementary notification of the breach of personal data protection was submitted to the Personal Data Protection Office, in which the Administrator included the missing content from the preliminary notification regarding the notification of the breach of personal data protection addressed to the individual concerned. However, the notification sent to the doctor lacked all the information specified in Article 34(2) in connection with Article 33(3) of Regulation 2016/679, i.e. a description of the possible consequences of the breach of personal data protection and a description of the measures taken or proposed by the administrator to remedy the breach – including, where appropriate, measures to minimize its potential negative effects.

In light of the above, by letters dated August 9, 2023, and September 13, 2023, the President of UODO requested the Minister of Health to provide answers to questions regarding:

- a) the legal basis for the Minister of Health's access to data on the issuance of e-prescriptions by the doctor for medications from the group of psychotropic and analgesic drugs and their disclosure via the social media platform X (formerly: Twitter);
- b) whether rules and procedures for granting permissions in the aforementioned system have been developed and implemented, and how their compliance has been monitored;
- c) whether the Administrator conducted a risk analysis regarding the processing of personal data related to the issued e-prescriptions via the system [...];

d) whether this analysis took into account threats related to unauthorized access to this data, as well as demonstrating the accountability of the system [...].

At the same time, the President of UODO requested clarification on which communication channel the personal data of the doctor was transmitted to the Minister of Health from the system [...] and how they were secured, as well as a general description of the technical and organizational security measures previously employed by the Administrator, measures taken or proposed to remedy the breach and minimize negative effects for the individual concerned, and what actions the Administrator plans to take to eliminate the risk of similar incidents occurring in the future, along with a timeline for their implementation. Furthermore, the President of UODO requested a new, correct notification to the individual concerned, due to the failure to provide them with all the information required under Article 34(2) in connection with Article 33(3) of Regulation 2016/679.

In the responses dated August 16, 2023, September 27, 2023, and October 13, 2023, the Administrator indicated the general purpose of processing the personal data contained in the system [...] and noted that "the publication of data from the system [...] had no basis in universally applicable law," presented the procedure for granting permissions in the system [...] along with information about the individuals authorized to use the system, as well as presented a risk analysis (without a date) for the processing of personal data using the system [...]. Additionally, the Administrator presented the security measures requested by the President of UODO along with the implementation date and indicated that the personal data of the doctor obtained from the system [...] was transmitted to the Minister of Health via the Whatsapp communicator. The Administrator also presented the content of the renewed notification addressed to the individual concerned.

In connection with the reported breach of personal data protection and the explanations provided by the Administrator in the aforementioned letters, on October 18, 2023, the President of UODO initiated ex officio administrative proceedings regarding the possibility of a breach by the Minister of Health, as the data administrator, of the provisions of Article 5(1)(a) and (f), Article 5(2), Article 6(1), Article 9(1), Article 24(1), Article 25

1. Article 32, paragraphs 1 and 2, and Article 34, paragraph 2, in connection with Article 33, paragraph 3 of Regulation 2016/679, regarding the violation of personal data protection of a doctor through the disclosure on the social media platform X (formerly Twitter) of information processed by the Administrator in the system [...] (reference number DKN.5131.32.2023.).

On December 1, 2023, in order to supplement the evidence, the President of the Personal Data Protection Office (UODO) requested the Minister of Health to clarify whether a procedure titled "[...]" had been developed, and whether the audits of the Ministry of Health and C. had been completed, along with the dates of their completion and the presentation of relevant reports. Furthermore, the President of UODO requested to indicate whether, prior to the occurrence of the personal data breach, the Administrator had developed and implemented procedures defining the principles and methods of transferring personal data, including data from the system [...], between the Ministry of Health and C., as well as the transfer of such personal data between individual organizational units of the Ministry of Health.

In response dated December 6, 2023, the Administrator provided information on the stage of work regarding the implementation of the aforementioned procedure, presented the dates of the audits' completion along with the reports, and presented the procedures in effect prior to the occurrence of the personal data breach, namely the procedure titled "[...]" applicable in C. and the procedures regarding granting and revoking permissions applicable in the Ministry of Health.

The supervisory authority assessed the evidence in terms of its credibility and evidential value. The President of UODO deemed the evidence submitted by the Administrator as credible. This is supported by the fact that the explanations provided by the Minister of Health are logical, coherent, and correlate with the entirety of the evidence and are confirmed by a series of documents provided by the Administrator.

In this factual state, after reviewing all the evidence collected in the case, the President of the Personal

Data Protection Office considered the following:

Article 5, paragraph 1 of the Act of April 28, 2011 on the information system in health protection (Journal of Laws of 2023, item 2465) indicates that the information system in health protection includes databases functioning within the System [...], specialized teleinformatics systems, and medical registers. Article 5, paragraph 2 of the aforementioned Act specifies that the information system is operated by the Platform [...] and the Electronic Platform [...], i.e., the system [...]. Article 7, paragraph 1, point 8 of the Act on the information system in health protection indicates that the Electronic Platform [...] (system [...]) is a teleinformatics system that enables, in particular, the access of the Minister responsible for health to data necessary for the implementation of tasks specified in Article 11, paragraph 1 of the Act of August 27, 2004 on health care services financed from public funds (Journal of Laws of 2022, item 2561, as amended).

In turn, Article 11, paragraph 1 of the Act on health care services financed from public funds states that the tasks of the Minister responsible for health in the scope covered by the Act include, in particular: 1) conducting and participating in education on preventing and solving problems related to the negative impact of environmental and social factors on health; 1a) conducting activities and participating in activities related to health promotion and disease prevention, including within the framework of health policy programs referred to in Article 48, and multiannual programs established under Article 136, paragraph 2 of the Act of August 27, 2009 on public finances (Journal of Laws of 2022, item 1634, as amended); 1b) establishing pilot programs referred to in Article 48e; 2) (repealed); 3) developing, financing, and evaluating the effects of health policy programs, as well as supervising their implementation; 3a) qualifying health care services as guaranteed services; 3b) approving and amending the tariff of services; 4) financing from the state budget, from the part remaining at the disposal of the Minister responsible for health, guaranteed services in the scope specified in the Act, including in relation to persons entitled to health care services under the coordination regulations; 4a) planning, transferring, and settling grants from the state budget referred to in Article 97, paragraph 8; 5) cooperating with non-governmental organizations of a regional or national character acting for health protection; 6) exercising supervision over health insurance in the scope specified in Chapter VII; 7) approving the financial plan of the Fund in agreement with the Minister responsible for public finances; 8) reviewing the financial report of the Fund; 9) submitting to the Sejm of the Republic of Poland by August 31 of the following year an annual report on the activities of the Fund prepared in the manner referred to in Article 187; 9a) appointing and dismissing the President of the Fund, the Vice Presidents of the Fund, members of the Fund Council, and directors of the regional branches of the Fund; 10) exercising supervision over the Agency; 11) approving the financial reports of the Agency; 12) developing, establishing, and updating the health needs map referred to in Article 95a, paragraph 1; 13) developing, establishing, monitoring, and updating the national transformation plan referred to in Article 95b, paragraph 1; 14) evaluating the draft provincial transformation plan referred to in Article 95c, paragraph 1, and approving it; 15) issuing opinions on the purposefulness of investments referred to in Article 95d, paragraph 1.

The above provisions unequivocally determine that the personal data of the doctor, which were obtained from the system [...] contrary to the purposes resulting from these provisions (which will be discussed in more detail later in this decision), and subsequently published on the platform social media platform X (formerly Twitter) is the Minister of Health, and not an individual appointed to this position. It is the Minister of Health who, in light of the aforementioned provisions, has been endowed with specific powers allowing access, in strictly defined cases and for specific purposes, to data processed in the system [...]. However, a violation of these principles when accessing personal data cannot result in the Minister of Health losing the status of administrator and being recognized as such by another entity (or individual). On the contrary, acting contrary to the principles of personal data processing described in the aforementioned legal provisions not only confirms a violation of these provisions and the provisions of Regulation 2016/679 regarding the legal bases for data processing but also indicates a failure to implement appropriate security measures to ensure data protection in the system [...], including against access to them in a manner inconsistent with the provisions of the Act on

the Information System in Health Protection and their use for purposes other than those specified in the aforementioned Act. It should be emphasized that the Minister of Health is responsible for both acquiring data from the information resources managed by him in accordance with specific provisions and only for the purposes indicated in those provisions, as well as for their further processing, i.e., in this case, the publication of that data on social media platform X (formerly Twitter). For this reason, the scope of this administrative proceeding also includes violations of those provisions of Regulation 2016/679 that relate to data security issues, for which the administrator, namely the Minister of Health, is responsible. There is no doubt that the development and proper implementation, in particular, of organizational security measures, e.g., in the form of appropriate procedures, could have prevented the violation of personal data protection that was reported to the President of the UODO on August 9, 2023. It should also be noted that the aforementioned report of a personal data breach made by the Minister of Health did not solely concern the fact of disclosing the personal data of a doctor on social media platform X (formerly Twitter) but also the violation of security principles related to the acquisition of that data from the system [...] and the manner of its transmission to the Minister of Health (via the WhatsApp messenger). In this context, for the recognition of the public administration body, i.e., the Minister of Health, as the administrator of that data and the addressee of this decision, the place where the personal data of the doctor was published is irrelevant, as the Minister of Health had no grounds for publishing the personal data of the doctor on any social media profile. Furthermore, it should be noted that the determinations contained in this decision do not exhaust all aspects of the case, and in particular do not preclude the personal liability of the individual holding the position of Minister of Health for actions that resulted in the violation of the personal data protection of the doctor, his rights and freedoms protected by the provisions of Regulation 2016/679, and his personal goods. In addition to other rights of the doctor that lie outside the competence of the President of the UODO (e.g., the possibility of filing civil law claims), he also has the right to file a complaint with the President of the UODO regarding the unlawful processing of his personal data by the Minister of Health acting "privately" as a natural person. Article 5 of Regulation 2016/679 sets out the principles concerning the processing of personal data that must be respected by all administrators, i.e., entities that independently or jointly with others determine the purposes and means of processing personal data. According to Article 5(1)(a) of Regulation 2016/679, personal data must be processed lawfully, fairly, and in a transparent manner in relation to the data subject ("lawfulness, fairness, and transparency"). Furthermore, according to Article 5(2) of Regulation 2016/679, the administrator is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate compliance ("accountability"). According to Article 6(1) of Regulation 2016/679, the processing of personal data is lawful only if at least one of the following conditions is met: a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes; b) processing is necessary for the performance of a contract to which the data subject is a party or to take steps at the request of the data subject prior to entering into a contract; c) processing is necessary for compliance with a legal obligation to which the administrator is subject; d) processing is necessary to protect the vital interests of the data subject or another natural person; e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the administrator; f) processing is necessary for the purposes of the legitimate interests pursued by the administrator or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child. It should be noted that the provision of Article 6(1)(f) of Regulation 2016/679 does not apply to the processing of personal data by public authorities in the course of performing their tasks. Article 9(1) of Regulation 2016/679 prohibits the processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, and processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, or data concerning the health, sexuality, or sexual orientation of that person. Recital 35 of Regulation 2016/679 specifies the concept of personal data concerning health, stating that "Personal data concerning health should include all data about the health status of the person to whom the data relates, revealing information about the past, present, or future physical or mental health status of the person to whom the data relates."

It should also be noted that according to Article 4(2) of Regulation 2016/679, "processing" means an operation or set of operations performed on personal data or sets of personal data, whether automated or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure, or destruction.

To assess the admissibility of the Minister of Health's use of personal data processed in the system [...], it is essential to refer to the positions developed in the jurisprudence of the Constitutional Tribunal and the Court of Justice of the European Union regarding public registers, as it should be assumed based on the content of Article 5(2) and Article 7(1) of the Act on the Information System in Health Protection that such a character pertains to the aforementioned system, including judgments developed as a result of the analysis of regulations on medical registers, as an element of the information system referred to in Article 5(1) of this Act, managed by the system [...].

It should therefore be indicated that the mere creation of medical registers, as emphasized by the Constitutional Tribunal in its judgment of December 18, 2014, K 33/13, OTK-A 2014, No. 11, item 120, "(...) may be considered necessary in a democratic state governed by the rule of law (Article 51(2) of the Constitution). Monitoring the demand for healthcare services and the health status of citizens, as well as conducting health prevention and implementing health programs, serve to ensure public safety and health (Article 31(3) of the Constitution). Considering these values may justify the limitation of constitutional freedoms and rights, provided that the scope and forms of such limitation meet the necessity criterion and do not violate the essence of freedoms and rights."

A similar position regarding public registers is presented by the Court of Justice of the European Union (CJEU), repeatedly emphasizing that "the provision of personal data to a third party, such as a public authority, constitutes an interference with the rights guaranteed by Articles 7[1] and 8[2] of the Charter of Fundamental Rights, regardless of how that data will subsequently be used" [similarly, judgments of May 20, 2003, Österreichischer Rundfunk and others, C-465/00, C-138/01, and C-139/01, EU:C:2003:294, paragraphs 74 and 75; as well as April 8, 2014, Digital Rights Ireland and others, C-293/12 and C-594/12, EU:C:2014:238, paragraphs 33–36; and also Opinion 1/15 (EU-Canada PNR Agreement) of July 26, 2017, EU:C:2017:592, paragraphs 124, 126]. According to the CJEU's case law, the rights guaranteed in Articles 7 and 8 of the Charter of Fundamental Rights of the European Union cannot be regarded as absolute prerogatives but should be assessed in light of their social function. Consequently, personal data should be processed for specific purposes and with the consent of the data subject or on another legitimate basis provided by law. Furthermore, according to the CJEU judgment of July 16, 2020, in case C-311/18, ECLI:EU:C:2020:559, "(...) to meet the requirement of proportionality, under which exceptions to the protection of personal data and its limitations may only be applied when absolutely necessary – it should contain clear and precise rules regarding the scope and application of the measure in question and establish minimum requirements to ensure that individuals whose personal data have been transferred are provided with sufficient safeguards to ensure the actual protection of their data against the risk of misuse. It should, in particular, indicate under what circumstances and under what conditions a measure allowing for the processing of such data may be adopted, thereby guaranteeing that the interference is limited to what is strictly necessary."

Article 47 of the Constitution of the Republic of Poland of April 2, 1997 (Journal of Laws No. 78, item 483, as amended) emphasizes that every person has the right to legal protection of their private life, family life, honor, and good name, as well as to decide about their personal life. The Constitutional Tribunal in its judgments has referred to this provision, indicating that the right to privacy also includes information about health status, which was emphasized in the ruling of June 24, 1997, case no. K 21/96, OTK ZU No. 2/1997, item 23, and in the judgment of November 20, 2002, case no. K 41/02, OTK ZU No. 6/A/2002, item 83.

Thus, it follows unequivocally from the case law of the CJEU and the Constitutional Tribunal that the provision of personal data contained in public registers to third parties constitutes a violation of the

fundamental rights and freedoms of individuals, infringes upon their privacy, and may lead to serious material and non-material consequences.

The violation by the Minister of Health of the protection of personal data of a physician resulting in the issuance of this decision concerns personal data processed in the system [...]. There is no doubt that the personal data contained in this system belong to special categories of personal data and, as such, are subject to special protection. It is also significant that the entities that have access to this system have been strictly defined by the provisions of the Act on the Information System in Health Protection (in Article [...]

7 ust. 1) along with a precise indication of the purposes for which such access may be realized, which constitutes the importance of the data processed therein and is meant to provide additional guarantees for that data. These provisions therefore exclude not only direct access by unauthorized persons to personal data contained in the system [...], but also limit the possibility of its use by authorized entities for purposes other than those specified by law.

In the case discussed, the Minister of Health unlawfully obtained personal data of a doctor from the system [...] for purposes not arising from the Act on the Information System in Health Care, and subsequently published it on social media platform X (formerly Twitter). It should be emphasized that prescriptions “pro auctore” can be issued by the doctor for their own needs; thus, as the name itself indicates, medications prescribed by the doctor using this category of prescriptions are intended for their exclusive use. Data concerning medications prescribed via such a prescription, as they can unequivocally indicate health conditions, constitute health data of the issuing doctor and are therefore subject to special protection under Article 9(1) of Regulation 2016/679. The disclosure of health data undoubtedly infringes upon the right to privacy of the doctor to whom the data pertains. As the Administrator himself indicates in the notification of the personal data breach, “Due to the media and political context of the personal data breach involving the public disclosure of personal data of an individual representing the medical community, and due to the information about the medication prescribed by the doctor, the breach may at least lead to an assumption about the health status, which is a special category of data. The disclosure of this information may have personal consequences for the individual (the doctor), even related to their employment due to the public disclosure of information about their workplace. Furthermore, given the political background of the matter, the individual whose data is concerned may face unpleasantness resulting from differing opinions from those with whom they interact, which seems likely given that the matter of data publication has been widely commented on in various media.” The Court of Justice of the European Union (CJEU) in its judgment of November 22, 2022, concerning joined cases C-37/20 and C-601/20, ECLI:EU:C:2022:912, emphasizes that “(...) the potential consequences for the individuals concerned arising from the possible improper use of their personal data are exacerbated by the fact that once publicly disclosed, such data can not only be freely viewed but also stored and disseminated, and in the case of such further processing, effective defense against improper use becomes more difficult, if not illusory, for those individuals.”

At this point, it should again be pointed out that the Minister of Health engaged in the processing of the doctor’s personal data for purposes inconsistent with the Act on the Information System in Health Care. It should be recalled that the aforementioned Act in Article 7(1)(8) states that the system [...] enables the minister responsible for health to access data necessary for the implementation of tasks specified in Article 11(1) of the Act of August 27, 2004, on health care services financed from public funds (Journal of Laws of 2022, item 2561). This provision enumerates the cases in which the processing of personal data contained in the system [...] by the Minister of Health is permissible, including conducting and participating in education on preventing and solving problems related to the negative impact of environmental and social factors on health; conducting activities related to health promotion and disease prevention; developing, financing, and evaluating the effects of health policy programs, as well as supervising their implementation; qualifying health care services as guaranteed services; planning, transferring, and settling subsidies from the state budget; cooperating with non-governmental organizations of a regional or national character working for health protection and supervising health insurance; submitting an annual report on the activities of the Fund to the Sejm of

the Republic of Poland. Article 11(1) of the Act on health care services financed from public funds does not foresee the acquisition of personal data from the system [...] by the Minister of Health for the purpose of publication, e.g., on social media platforms for the “defense of the good name of the Ministry of Health” and “defense of the interests of the patient.” Such actions by the Minister of Health are also consequently inconsistent with the Constitution of the Republic of Poland, which in Article 7 states that public authorities act on the basis of and within the limits of the law.

The above clearly establishes that the acquisition by the Minister of Health from the system [...] of the doctor’s personal data regarding their name, surname, and health data (information about the issued “pro auctore” prescription for medications from the groups of psychotropic and analgesic drugs), as inconsistent with the purposes of processing personal data specified in the aforementioned legal provisions, occurred without legal basis, and consequently in violation of Article 6(1) and Article 9(1) of Regulation 2016/679, which simultaneously constitutes a violation of the principle of legality expressed in Article 5(1)(a) of Regulation 2016/679. Thus, the Minister of Health, by publicly disclosing the doctor’s personal data in the aforementioned scope, deprived them of their constitutional right to legal protection of private life and to decide about their personal life. It should also be noted that the Administrator himself recognized irregularities in his actions, admitting in a letter dated September 27, 2023, that “The publication of personal data from the system [...] had no basis in the provisions of generally applicable law.”

It should be emphasized that the situation is reprehensible, in which the Minister of Health uses personal data contained in specialized registers for purposes other than those specified in legal provisions. The Minister of Health, exercising his powers arising from his position, by issuing an order to his employees to obtain data from the system [...] and to provide him with the personal data of a physician, abused his position, and by publishing this data on the social media platform X (formerly Twitter), betrayed the trust of citizens, who as a result of this violation cannot be certain whether their data is also adequately protected.

Thus, the President of the Personal Data Protection Office (UODO) found that the Minister of Health violated Article 5(1)(a) of Regulation 2016/679 in connection with the processing of personal data of the aforementioned individual without legal basis, and therefore in violation of Article 6(1) and Article 9(1) of Regulation 2016/679, and consequently Article 5(2) of Regulation 2016/679, i.e., the principle of accountability.

According to Article 5(1)(f) of Regulation 2016/679, personal data must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures (“confidentiality and integrity”).

Furthermore, according to Article 5(2) of Regulation 2016/679, the controller is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate compliance (“accountability”). The specification of the principle of confidentiality referred to in Article 5(1)(f) of Regulation 2016/679 is provided by further provisions of this legal act. According to Article 24(1) of Regulation 2016/679, taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities and severity, the controller implements appropriate technical and organizational measures to ensure that processing is performed in accordance with this regulation and to be able to demonstrate it. These measures are reviewed and updated as necessary.

Pursuant to Article 25(1) of Regulation 2016/679, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity arising from processing, the controller—both when determining the means of processing and during the processing itself—implements appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement data protection principles, such as data minimization, and to provide necessary safeguards for processing to meet the requirements of this

regulation and protect the rights of data subjects.

From the content of Article 32(1) of Regulation 2016/679, it follows that the controller is obliged to apply technical and organizational measures corresponding to the risk of infringement of the rights and freedoms of natural persons with varying probabilities of occurrence and severity of threat. The provision specifies that when deciding on technical and organizational measures, consideration must be given to the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, and the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity. From the cited provision, it follows that determining appropriate technical and organizational measures is a two-step process.

First, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria indicated in Article 32(1) of Regulation 2016/679, and then to establish what technical and organizational measures will be appropriate to ensure a level of security corresponding to that risk. These determinations, where appropriate, should include measures such as pseudonymization and encryption of personal data, the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, the ability to restore the availability of personal data and access to it in a timely manner in the event of a physical or technical incident, and regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure processing security.

According to Article 32(2) of Regulation 2016/679, when assessing whether the level of security is appropriate, the controller takes into account, in particular, the risks associated with processing, especially those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed.

The provisions of law cited in Part II of this decision and the referenced rulings of the Court of Justice of the European Union (CJEU) and the Constitutional Tribunal (TK) indicate the seriousness of the data protection violation committed by the Minister of Health. The unambiguous sensitivity of personal data processed in public registers, including in the system [...], determines the obligation for the data controller to implement appropriate security measures that not only ensure protection for this personal data but also build a sense among the public that their data will be used solely for legitimate and legally defined purposes. In this context, organizational security measures are of particular importance, as they can primarily counteract any abuses and misuse of data collected in public registers, including in the system [...], for purposes inconsistent with those specified in the relevant provisions. The selection of appropriate security measures, therefore, includes both technical measures.

i organizational, should be preceded by a risk analysis, based on which the Administrator identifies threats to the processed personal data and determines the degree of risk of infringement of the rights or freedoms of individuals in situations such as, for example, the occurrence of a breach of confidentiality of that data. At this point, it should be noted that Regulation 2016/679 introduced an approach in which risk management is the foundation of activities related to the protection of personal data. Risk management is a continuous process that requires the administrator not only to ensure compliance with the provisions of Regulation 2016/679 through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and to ensure accountability regarding the level and adequacy of the implemented safeguards. Therefore, it becomes necessary to be able to prove to the supervisory authority that the solutions introduced to ensure the security of personal data are adequate to the level of risk and also take into account the nature of the organization and the mechanisms used for processing personal data. The Administrator must independently conduct a detailed analysis of the data processing processes and assess the risk, and then apply such measures and procedures that will be adequate to the estimated risk. The consequence of such an approach is the necessity of independently selecting safeguards based on a threat analysis. Specific security measures and procedures are not indicated to the administrators. In the judgment of August 26, 2020, case no. II SA/Wa 2826/19, the Provincial Administrative Court in Warsaw stated that "This provision [Article 32 of Regulation 2016/679] does not require the data administrator to implement any technical and organizational measures that are to

constitute personal data protection measures, but requires the implementation of adequate measures. Such adequacy should be assessed in terms of the manner and purpose for which personal data is processed, but it is also necessary to take into account the risks associated with the processing of that personal data, which may vary in magnitude.”, “The adopted measures must be effective; in specific cases, some measures will have to mitigate low risk, while others must mitigate high risk; however, it is important that all measures (as well as each one individually) are adequate and proportional to the level of risk.”, and also “(...) technical-organizational activities are the responsibility of the personal data administrator, but they cannot be selected in a completely free and voluntary manner, without considering the level of risk and the nature of the protected personal data.”

In light of the above, a properly conducted risk analysis provides the administrator with the opportunity to determine and implement technical and organizational measures that will eliminate or at least significantly reduce the established level of risk of materialization of identified threats to the processed personal data. The risk assessment conducted by the administrator should be documented and justified by the factual state existing at the time it is conducted. The main factors that make up a proper assessment, which should be taken into account during the analysis, are the characteristics of the processing processes, assets, vulnerabilities, threats, and current safeguards. It should be remembered that significant factors in assessing risk also include the scope and nature of the personal data processed by the administrator, as these will determine any potential negative consequences for the individual occurring at the moment of a breach of the protection of their personal data.

The Administrator, along with the letter dated August 16, 2023, presented a risk analysis sheet in connection with unauthorized access to data processed using the system [...]. There is no information indicating the date of this analysis, and the presented risk sheet is described as “current risks.” In the presented sheet, the Administrator identified specific risks for the data, such as “Risk - access to the database for unauthorized users,” “Risk of processing personal data without a legal basis,” and “Risk of loss of information security caused by accidental or intentional actions of an employee in the system [...]” The analysis of the risk description and its causes allows for the conclusion that the risk most closely related to the situation subject to this administrative proceeding is “Risk of loss of information security caused by accidental or intentional actions of an employee in the system [...],” as the cause indicated was the low awareness of employees regarding the sensitivity of the data processed in the system and the insufficient implementation of security procedures (while in the case of “Risk of processing personal data without a legal basis,” the cause is “Legislative changes regarding the processing of personal data, lack of communication between organizational units processing personal data and the Data Protection Officer”). “Risk of loss of information security caused by accidental or intentional actions of an employee in the system [...]” was assessed at a medium level, and the security measures proposed by the Administrator include the introduction of periodic awareness training on data security and cybersecurity.

Even if we assume that the described risk encompasses the situation of transferring personal data from the system [...] to an authorized entity, but contrary to the purposes defined in the legal provisions, and then publishing them, for example, on a social media platform, the proposed measures to eliminate or at least limit this risk are still not adequate.

****Translation of the Legal Document Text:****

because training in data security and cybersecurity alone will not achieve this goal without the introduction of appropriate procedures that define the course of action in such situations. The Administrator also recognized this, who, after a breach of personal data protection, began developing a procedure titled “[...]”. Furthermore, recommendations in this regard were formulated in the “Report [...]” (task number [...]) dated (...) October 2023, where it was indicated, among other things, that “A change to the Agreement by C. together with the Ministry of Health is required in the part concerning the issuance of orders by the Minister of Health, so that any orders are issued in an official manner and include the wording ‘order’ (instead of via email) and the introduction of a ban on using other communication channels not specified in the Agreement [e.g., the WhatsApp messenger – own note],” “The introduction of a process or regulation regarding the obtaining by employees (including members

of the management) of the Ministry of Health of personal data collected in IT systems operated by C. (the systems referred to in the Act of April 28, 2011, on the information system in health protection, with particular regard to the prior position of the Information Security Officer and the Data Protection Inspector (as a necessary and essential element)" and "The introduction in the Ministry of Health of a process/regulation covering the area of sharing personal data, for which the Minister of Health is the administrator, to authorized entities and institutions, including a central register of requests covering their implementation." It should be emphasized that the procedures referred to in the aforementioned recommendations cannot be replaced by the procedure functioning in C. "[...]", as this entity is solely the administrator of the system, pursuant to Article 7(2) of the Act on the information system in health protection, and the procedures in this regard must be developed and implemented by the administrator, i.e., by the Minister of Health. Considering that the breach of personal data protection was caused by the actions of the Administrator itself, it seems appropriate that such a risk be described separately, which would ensure the selection of security measures strictly dedicated to this risk, taking into account the specifics of the relationships related to employment subordination.

The risk in this regard is further increased by the fact that personal data of a doctor obtained from the system [...] were transmitted to the Minister of Health via the WhatsApp messenger, a channel for data transmission that was not identified in the conducted risk analysis. The means of communication used by the Minister of Health cannot be considered as one that can be used for communication by public administration bodies due to the demonstrated violations of the provisions of Regulation 2016/679. The owner of the WhatsApp messenger was penalized in 2021 by the Irish supervisory authority (Data Protection Commission, hereinafter DPC) with an administrative fine of 225 million euros for a lack of transparency in the processing of personal data, manifested, among other things, by failing to indicate what personal data and in what situations are shared with other applications and other entities belonging to the Facebook (Meta) capital group. Relatively recently, on January 12, 2023, WhatsApp Ireland Limited was again penalized by the DPC with an administrative fine of 5.5 million euros along with an order to adjust processing operations to the provisions of Regulation 2016/679, following a binding decision of the European Data Protection Board (EDPB) dated December 5, 2022, issued under Articles 63 and 65 of Regulation 2016/679 within the framework of the consistency mechanism, in connection with the failure to fulfill the obligation regarding transparency. In the DPC decision, it was indicated that the information regarding the legal basis on which WhatsApp IE relied for processing was not clearly presented to users, which resulted in users not being aware of what processing operations were being conducted on their personal data and for what purpose. The EDPB issued a decision confirming that the position of the DPC as the lead authority regarding the violation of transparency requirements, i.e., Article 5(1)(a) of Regulation 2016/679, was maintained.

The use of the indicated messenger, while simultaneously lacking an established procedure regulating the rules for requesting the transfer of personal data collected in IT systems, and thus in the system [...], indicates a lack of application of any security measures in the processing of personal data of the doctor, whose personal data was ultimately disclosed by the Minister of Health on the social media platform X (formerly Twitter). Moreover, the violations of the provisions of Regulation 2016/679 by the owner of this messenger, as evidenced in the aforementioned DPC decisions, indeed only increase the risks of unlawful use of this data, if only due to the potential access to this data by other entities within the Meta capital group. The lack of risk analysis in this regard also prevented the Minister of Health from identifying other threats related, for example, to security, which may cause violations of the rights or freedoms of individuals whose data are processed in the system [...], and may lead to serious consequences of such a violation related to the complete loss of control over the personal data transmitted via the aforementioned messenger.

It should also be emphasized that in the report from the audit conducted in C. concluded on October 30, 2023, it was indicated in point 2 of this report that the Personal Data Security Policy in force in the institution refers to outdated regulations, as well as that the applied...

is an outdated approach to personal data protection. One of the recommendations formulated after the audit is to "Develop a data security policy in accordance with GDPR." The report indicates the

necessity of adjusting the level of security of processing operations to the level of risk associated with each operation. This points to a low awareness among employees responsible for processing personal data in C., which should further contribute to actions taken by the Ministry of Health to improve the quality of personal data security, for which the Minister of Health is the administrator, and which are processed by C. as the system administrator.

Ultimately, it must be stated that by transmitting a doctor's personal data via the WhatsApp messenger, the Administrator created the possibility of losing control over that data, including its security. It is important to emphasize that when applying the provisions of Regulation 2016/679, it should be considered that the purpose of this regulation is to protect the fundamental rights and freedoms of natural persons, in particular their right to personal data protection, as stated in Article 1(2) of this legal act. In the event of any doubts regarding the necessity to fulfill the obligations arising from Regulation 2016/679, the administrator is obliged to primarily consider these values.

Due to the Administrator's failure to apply adequate security measures aimed at ensuring the protection of data processed using the system [...], it must be stated that the Minister of Health did not ensure an appropriate level of security for the data processed using it. This constitutes a violation by the Administrator of the obligation to implement appropriate technical and organizational measures during the processing of personal data, so that this processing is carried out in accordance with Regulation 2016/679 and to provide the necessary safeguards for processing, which he was obliged to do under Article 24(1) and Article 25(1) of Regulation 2016/679, as well as the obligation to apply technical and organizational measures ensuring a level of security corresponding to the risk of violation of the rights or freedoms of natural persons, including the ability to continuously ensure the confidentiality of that data, to which the administrator is obliged under Article 32(1) of Regulation 2016/679, taking into account the risks associated with the processing of personal data referred to in Article 32(2) of Regulation 2016/679, and consequently also a violation of the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679, which the aforementioned provisions detail. The effect of the violation of the principle of confidentiality is a breach of Article 5(2) of Regulation 2016/679. As indicated by the Provincial Administrative Court in Warsaw in its judgment of February 10, 2021 (case no. II SA/Wa 2378/20, Legalis no. 2579568), "(...) the data administrator is responsible for complying with all principles when processing personal data (listed in Article 5(1)) and must be able to demonstrate compliance. The principle of accountability thus relies on the legal responsibility of the administrator for properly fulfilling obligations and imposes on him the duty to demonstrate, both before the supervisory authority and before the data subject, evidence of compliance with all data processing principles." Similarly, this issue was interpreted by the Provincial Administrative Court in Warsaw on August 26, 2020 (case no. II SA/Wa 2826/19, Legalis no. 2480051), stating that "[t]aking into account the entirety of the norms of Regulation 2016/679, it should be emphasized that the administrator has considerable freedom regarding the security measures applied, while at the same time being responsible for violations of personal data protection regulations. The principle of accountability directly implies that it is the administrator who should demonstrate, and thus prove, that he complies with the principle set out in Article 5(1) of Regulation 2016/679."

According to Article 34(1) of Regulation 2016/679, if a personal data breach may result in a high risk of violation of the rights or freedoms of natural persons, the administrator shall notify the data subject of such a breach without undue delay. Pursuant to Article 34(2) of Regulation 2016/679, the notification referred to in paragraph 1 of this article shall describe the nature of the personal data breach in clear and plain language and shall at least contain the information and measures referred to in Article 33(3)(b), (c), and (d). Furthermore, according to Article 33(3) of Regulation 2016/679, the notification referred to in paragraph 1 must at least: a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects concerned, as well as the categories and approximate number of personal data records concerned; b) contain the name and contact details of the data protection officer or another contact point from which more information can be obtained; c) describe the likely consequences of the personal data breach; d) describe the measures taken or proposed by the administrator to address the personal data breach, including,

where appropriate, measures to mitigate its possible adverse effects.

In the supplementary notification of the personal data breach, the Administrator informed that he had notified the data subject of the breach of her personal data and provided the content of that notification. As a result of the analysis of the content of the notification provided to the data subject, as well as the nature of the breach that occurred, its duration, the categories of data, and the categories of persons affected by the breach, as well as the remedial measures taken, the President of the UODO concluded that the breach...

****Confidentiality of Data, Particularly Name and Surname Along with Health Data****

The breach of confidentiality of data, particularly name and surname along with health-related data, poses a high risk of infringement of the rights or freedoms of natural persons. Therefore, it is necessary to promptly and correctly notify the data subject of the breach of their personal data protection. The notification presented by the Administrator lacked all the information required pursuant to Article 34(2) in connection with Article 33(3) of Regulation 2016/679, namely a description of the possible consequences of the breach of personal data protection and a description of the measures taken or proposed by the administrator to address the breach – including, where appropriate, measures to minimize its negative effects. In this regard, on September 13, 2023, the President of the UODO requested the Administrator to take actions aimed at promptly, correctly notifying the data subject and eliminating similar irregularities in the future, by providing that person, as part of the re-notification of the breach of personal data protection, with a description of the possible consequences of the breach of personal data protection and a description of the measures taken or proposed by the administrator to address the breach – including, where appropriate, measures to minimize its negative effects.

In response, in a letter dated October 13, 2023, the Administrator provided the content of the repeated notification directed to the data subject. An analysis of the content of the repeated notification sent to the physician revealed that the Administrator did not adjust the content of this letter to the guidelines presented in the President of the UODO's request of September 13, 2023, as it did not include a correct description corresponding to the scope of personal data covered by the breach of personal data protection, a description of the possible consequences of the breach of personal data protection, and a description of the measures taken or proposed by the administrator to address the breach – including, where appropriate, measures to minimize its negative effects.

The inaccuracy of the presented data regarding the possible consequences of the breach of personal data protection is primarily manifested in their imprecise definition. In the anonymized content of the repeated notification regarding the breach of personal data protection, directed to the physician whose data are concerned, the Administrator indicated that "As a result of the aforementioned action, there may have been a breach of the confidentiality of personal data. The disclosure of your personal data may lead to assumptions about your health status. There is also a potential risk that the data may be used, for example, for impersonation in order to obtain additional information." The above description of the possible consequences is insufficient for the data subject to understand what real consequences of the breach may await them in connection with the disclosure of their personal data, including health data. Above all, in a situation where personal data has already been disclosed, it is not appropriate to indicate to the data subject that "there may have been a breach of confidentiality of data." Such action may mislead the data subject and create a false impression that, in reality, third parties have not gained access to the data. Furthermore, in describing the possible consequences of the breach of personal data protection, the Minister of Health completely omitted the fact of the disclosure on the social media platform X (formerly Twitter) of health-related data, which resulted in a lack of information being provided to the physician whose data are concerned about the possible effects of the breach of this category of data. In the notification, the Administrator also did not include any description of remedial measures that the data subject could independently implement to minimize the effects of the breach, limiting itself only to describing the actions taken by the Minister of Health.

As indicated in Guidelines 9/2022, a breach of personal data protection may potentially lead to a range of negative consequences for the natural persons whose data are subject to the breach of personal

data protection. Among the possible consequences of the breach, the EROD mentions: physical harm, material or non-material damages. Examples of such damages include, among others: discrimination, identity theft or identity fraud, financial losses, damage to reputation, breach of confidentiality of personal data, and significant economic or social harm. It is indisputable that, given that the breach of personal data protection involved health data along with name and surname, the consequences may primarily manifest as discrimination or damage to the reputation of the person to whom this data pertains. The media context of the breach of personal data protection and the recognizability of the physician associated with their public appearances, which allows for the unequivocal identification of that person, are also significant for such an assessment.

It should also be noted that the proper execution by the Administrator of its obligation arising from Article 34(1) of Regulation 2016/679, related, among other things, to the necessity of providing all required information in the notification of the breach of personal data protection, pursuant to Article 34(2) in connection with Article 33(3) of Regulation 2016/679, cannot be conditioned upon the occurrence of an infringement of the rights or freedoms of that person as a result of the materialization of possible negative consequences of the breach (cf. judgments of the Provincial Administrative Court in Warsaw of September 22, 2021, file no. II SA/Wa 791/21, of July 1, 2022, file no. II SA/Wa 4143/21, of August 31, 2022, file no. II SA/Wa 2993/21, of November 15, 2022, file no. II SA/Wa 546/22, and of April 26, 2023, file no. II SA/Wa 1272/22).

It should be emphasized at this point that data concerning health, in accordance with Regulation 2016/679, belong to special categories of personal data and, as such, are subject to specific processing rules and should be afforded special protection by their controllers. In the event of a personal data breach, this creates a high risk of infringement of the rights or freedoms of the individual, which obliges the controller to notify that individual of the personal data breach, including information specified in Article 34(2) in connection with Article 33(3) of Regulation 2016/679. However, in the case of the aforementioned personal data breach, the Minister of Health did not provide the affected individual with all the required information, namely a description of the possible consequences of the personal data breach and a description of the measures taken or proposed by the controller to address the breach – including, where appropriate, measures to minimize its negative effects related to the breach of health data.

The consequence of such action by the Controller is the possibility of the data subject not fully understanding the significance of the breach that has occurred. Moreover, the lack of indication of the measures proposed by the Controller to address the breach and minimize its potential effects may prevent the data subject from making an informed decision regarding the self-protection of their data against unauthorized use. The EDPB in its guidelines indicates that the main purpose of notifying individuals is to provide specific information about the steps they should take to protect themselves from the negative consequences of the breach of their personal data. It should be emphasized that the measures proposed to the data subject to address the breach, including measures to minimize its negative effects, should correlate with the possible negative consequences of the breach of personal data presented to that individual.

At this point, it should be noted that Articles 34(1) and (2) of Regulation 2016/679 aim not only to ensure the most effective protection of the fundamental rights or freedoms of data subjects but also to implement the principle of transparency, which arises from Article 5(1)(a) of Regulation 2016/679 (see Chomiczewski Witold [in:] GDPR. General Regulation on Data Protection. Commentary. ed. E. Bielak-Jomaa, D. Lubasz, Warsaw 2018). Proper execution of the obligation specified in Article 34 of Regulation 2016/679 should provide the data subject with quick and transparent information about the breach of their personal data along with a description of the possible consequences of the breach of personal data and the measures they can take to minimize its potential negative effects.

In light of the above, it should be noted that in order to safeguard the interests of the data subject and act in accordance with the law, the Controller should have ensured that this individual had the best possible opportunity for an independent assessment of the infringement of their rights or freedoms in connection with the incident that occurred. Achieving this goal requires the Controller to provide the

data subject with at least the information listed in Article 34(2) of Regulation 2016/679 in a form that allows the data subject to review the content of the notification addressed to them multiple times.

Consequently, it must be stated that the Controller, when notifying the data subject of the breach of their personal data, did not provide them with all the required information in accordance with Article 34(2) in connection with Article 33(3) of Regulation 2016/679, namely a description of the possible consequences of the breach of personal data and a description of the measures taken or proposed by the controller to address the breach – including, where appropriate, measures to minimize its negative effects, which constitutes a violation of these provisions by the Minister of Health.

When assessing the circumstances of the personal data breach, it should be emphasized that when applying the provisions of Regulation 2016/679, it should be borne in mind that the purpose of this regulation (expressed in Article 1(2)) is to protect the fundamental rights and freedoms of individuals, particularly their right to the protection of personal data, and that the protection of individuals in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In the event of any doubts, for example, regarding the performance of obligations by controllers – not only in situations where a personal data breach has occurred but also when developing technical and organizational security measures to prevent them – these values should be taken into account first and foremost.

At this point, it should be noted that according to Article 34(4) of Regulation 2016/679, if the controller has not yet notified the data subject of the personal data breach, the supervisory authority – taking into account the likelihood that this personal data breach will result in a high risk – may require the controller to do so or may determine that one of the conditions referred to in paragraph 3 has been met. Furthermore, Article 58(2)(e) of Regulation 2016/679 states that each supervisory authority has the corrective power to order the controller to notify the data subject of the personal data breach.

Considering the above findings and the identified violations of the provisions of Regulation 2016/679, the President of the UODO, exercising the authority granted to him under Article 58(2)(i) of Regulation 2016/679, according to which each supervisory authority has the power to apply, in addition to or instead of other corrective measures...

the violation of the provisions concerning the obligations of the administrator and the processor, as referred to in Articles 8, 11, 25-39, and 42 and 43, are subject, according to paragraph 2, to an administrative fine of up to EUR 10,000,000, and in the case of an enterprise - up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

According to Article 83(5)(a) of Regulation 2016/679, violations of the provisions concerning the fundamental principles of processing, including the conditions for consent, as referred to in Articles 5, 6, 7, and 9, are subject, according to paragraph 2, to an administrative fine of up to EUR 20,000,000, and in the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

In this case, the administrative fine imposed on the Administrator was for the violation of Article 25(1), Article 32(1) and (2), and Article 34(2) in connection with Article 33(3) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for the violation of Article 5(1)(a) and (f), Article 5(2), Article 6(1), and Article 9(1) of Regulation 2016/679 - based on Article 83(5)(a) of this regulation.

In deciding to impose an administrative fine, the President of the UODO - in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 - took into account the following circumstances of the case, which necessitate the application of this type of sanction in this case and which have a detrimental impact on the amount of the imposed administrative fine:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). The violation established in this case is of significant weight and serious nature, as it creates a high risk of negative legal and factual

consequences for the doctor whose data was disclosed on the aforementioned platform. The violation of the provisions of Regulation 2016/679 not only entails a potential but also a real possibility of the data being used by third parties without the knowledge and against the will of the data subject, in violation of the provisions of Regulation 2016/679. The risk of harm in the form of discrimination, loss of reputation, or loss of patient trust, which is essential for a doctor's work, is undoubtedly increased by the fact that the violation of personal data protection involved health-related data in the form of information about a prescription issued "pro auctore" for a drug from the group of psychotropic and analgesic medications. Furthermore, the individual whose data was disclosed may feel apprehensive about losing control over their personal data, and as indicated by the District Court in Warsaw in its judgment of August 6, 2020, case file XXV C 2596/19, the fear, and thus the loss of a sense of security, constitutes a real non-material damage associated with the obligation to remedy it. It is also significant that the number of individuals at risk of a violation similar to that discussed in this decision is greater, as it includes all individuals whose data is processed in the system [...].

In this case, there was widespread access to the personal data published by the Minister of Health, as the post containing personal data was widely commented on in the media. The long duration of the violation is also significant, as the Administrator did not implement appropriate organizational security measures (e.g., procedures) aimed at preventing the situation that is the subject of this proceeding. Moreover, the individual whose data is concerned has still not received complete information regarding the violation of their personal data protection, in accordance with Article 34(2) in connection with Article 33(3) of Regulation 2016/679.

In this case, the violation concerned the personal data of only one individual. Such a number of individuals affected by the violation, especially given the fact that the Minister of Health processes the personal data of a very large number of individuals using the system [...], should be considered small, which undoubtedly works in favor of the Administrator, but this did not change the overall assessment, i.e., the recognition in the analyzed case of the premise from Article 83(2)(a) of Regulation 2016/679 as aggravating.

2. The intentional nature of the violation (Article 83(2)(b) of Regulation 2016/679). According to the Guidelines of the Article 29 Working Party on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 WP253 (adopted on October 3, 2017, approved by EROD on May 25, 2018), hereinafter referred to as the WP253 Guidelines, intent "includes both knowledge and purposeful action, in relation to the characteristics of the prohibited act." Unauthorized access to the personal data of the doctor whose data was made public by the Administrator on the social media platform X (formerly Twitter) became possible as a result of the intentional actions of the Minister of Health without a justified purpose under the provisions of the Act on the Information System in Health Protection and due to the lack of appropriate organizational security measures (e.g., procedures) that could potentially prevent this. Furthermore, in a conscious manner... of the GDPR) and ensuring compliance with data protection regulations.

3. Actions taken to minimize damage suffered by data subjects (Article 83(2)(c) of Regulation 2016/679). The Administrator did not take any other actions—apart from removing the entry on the Ministry of Health's profile on the social media platform X (formerly Twitter)—that could have been taken in this situation, such as apologizing to the doctor, expressing regret, or publicly acknowledging the mistake, which could have mitigated the harm suffered by the affected individual. As indicated by the resolution of the Supreme Court dated June 28, 2006, case no. III CZP 23/06, "According to Article 24 of the Civil Code, a person whose rights have been violated may demand, among other things, that the person who committed the violation take actions necessary to eliminate its effects, and in particular, to make a statement of appropriate content and in an appropriate form. In jurisprudence and civil law doctrine, it is generally accepted that the content of the statement may include an apology or expression of regret, while the form of the statement—dependent on the circumstances of the specific case—refers to the manner of its announcement to other persons or public announcement, thus making it available to a larger group of unspecified individuals. There can be no doubt that the regulation contained in Article 24 of the Civil Code, which constitutes an element of the broadly

understood protection of personal rights, primarily protects the interests of the person affected by the violation. This fact cannot be indifferent when resolving the presented legal issue, especially in contemporary times, in light of the increased threat to personal rights from mass media and participants in public debate, as well as in connection with the disintegration of good manners in both private and public life." The above indications presented by the Supreme Court regarding actions aimed at eliminating the effects of violations of personal rights are, in the opinion of the President of the UODO, also applicable to actions that can be taken to remedy non-material damage (harm) caused by the violation of personal data protection.

4. Categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679). The personal data published by the Minister of Health on the social media platform X (formerly Twitter), as well as a large portion of the data processed in the registers administered by the Minister of Health (including using the system [...]), constitute data subject to special protection under Article 9(1) of Regulation 2016/679. This imposes an obligation on the administrators of this data to treat this information with particular care, also due to the possible negative consequences for the individuals to whom this data pertains in the event of its disclosure to unauthorized persons, including discrimination or loss of reputation. In determining the amount of the administrative monetary penalty, the President of the UODO found no grounds to consider any mitigating circumstances that could influence the reduction of the final penalty imposed on the Minister of Health. Other circumstances mentioned in Article 83(2) of Regulation 2016/679, after assessing their impact on the violation established in this case, were deemed neutral by the President of the UODO, meaning they had neither an aggravating nor mitigating effect on the amount of the imposed administrative monetary penalty.

1. Degree of responsibility of the administrator, taking into account the technical and organizational measures implemented by them under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). The President of the UODO found that the Minister of Health violated the provisions of Articles 25(1) and 32(1) and (2) of Regulation 2016/679. In his opinion, the administrator bears a high degree of responsibility for failing to implement appropriate technical and organizational measures that would have prevented the violation of personal data protection. It is evident that in the context of the nature, purpose, and scope of personal data processing, the Administrator did not "do everything that could have been expected of him"; thus, he did not fulfill the obligations imposed on him by Articles 25 and 32 of Regulation 2016/679. In this case, this circumstance constitutes the essence of the violation itself; it is not merely a factor influencing—either mitigating or aggravating—its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Articles 25 and 32 of Regulation 2016/679 cannot be recognized by the President of the UODO in this case as a circumstance that could additionally influence a stricter assessment of the violation and the amount of the administrative monetary penalty imposed on the Administrator.

2. Any relevant prior violations by the administrator or processor (Article 83(2)(e) of Regulation 2016/679). The President of the UODO did not find any relevant prior violations of Regulation 2016/679 by the Minister of Health, and therefore there are no grounds to treat this circumstance as aggravating; however, it is the duty of every administrator to comply with the law (including the provisions of the GDPR) and ensure compliance with data protection regulations.

concerning the protection of personal data), therefore the absence of prior similar violations of personal data protection cannot be considered a mitigating circumstance when imposing sanctions.

3. The degree of cooperation with the supervisory authority in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The Minister of Health has taken certain actions that can be considered aimed at remedying the effects of the violation; he removed the entry from the Ministry of Health's profile on platform X (formerly Twitter), attempted to notify the doctor whose data is concerned about the violation of the protection of his personal data, and also began work on appropriate procedures to prevent such situations in the future. However, these actions cannot be considered effective. The Minister of Health failed during the course of these proceedings to implement technical and organizational measures adequate to the risk of processing personal data using the system [...]; he also did not effectively and in accordance with legal

requirements notify the person concerned about the violation of the protection of his personal data. Furthermore, the mere removal of the entry from the Ministry of Health's profile on platform X – although it resulted in the removal of the state of violation consisting of processing personal data of the doctor without a legal basis – did not significantly mitigate the effects of this violation. The great importance of the violation consisting of the unlawful publication of personal data on the Internet, especially on social media, lies in the fact that its negative effects are immediate and practically irreversible. It is extremely difficult for a person affected by such a violation to regain control over their personal data and enforce their right to "be forgotten" in the online space. In this regard, the ineffectiveness (as of the date of this decision) of the actions taken by the Minister of Health aimed at remedying the identified violations and mitigating their negative effects does not allow for their consideration – as a mitigating circumstance – when determining the amount of the imposed administrative monetary penalty.

4. The manner in which the supervisory authority became aware of the violation (Article 83(2)(h) of Regulation 2016/679). The President of the Personal Data Protection Office (UODO) identified the violation of the provisions of Regulation 2016/679 as a result of a report of a personal data breach made by the Administrator. In making this report, the Administrator was merely fulfilling a legal obligation, and there are no grounds to consider this circumstance as a mitigating factor. According to the Guidelines WP253, "The supervisory authority may become aware of a violation as a result of proceedings, complaints, articles in the press, anonymous tips, or notification by the data controller. According to the regulation, the controller is obliged to notify the supervisory authority of a personal data breach. The mere fulfillment of this obligation by the controller cannot be interpreted as a mitigating factor."

5. Compliance with previously applied measures in the same case referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Prior to issuing this decision, the President of UODO did not apply any of the measures listed in Article 58(2) of Regulation 2016/679 against the administrator in the case under consideration, which means that the administrator had no obligation to take any actions related to their application, and such actions, assessed by the President of UODO, could have a burdening or mitigating impact on the assessment of the identified violation.

6. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). The Minister of Health does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not – as stipulated by the provisions of Regulation 2016/679 – mandatory for controllers and processors, which means that the circumstance of their non-application cannot be considered against the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection for processed personal data could be taken into account in favor of the Administrator.

7. Financial benefits obtained directly or indirectly in connection with the violation or avoided losses (Article 83(2)(k) of Regulation 2016/679). The President of UODO did not find that the administrator obtained any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds to treat this circumstance as burdening the administrator. The existence of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. However, the absence of such benefits for the administrator, as a natural state independent of the violation and its effects, is a circumstance that inherently cannot be mitigating for the Administrator. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "obtained" – that is, those that occurred on the part of the entity committing the violation.

8. Other aggravating or mitigating factors (Article 83(2)(k) of Regulation 2016/679). The President of UODO, having comprehensively examined the case, did not note any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed administrative monetary penalty.

Considering all the circumstances discussed above, the President of the Personal Data Protection Office has determined that the imposition of an administrative monetary penalty on the Minister of

Health is necessary and justified by the gravity, nature, and scope of the alleged violations of the provisions of Regulation 2016/679 attributed to the Administrator. It should be noted that the application of any other corrective measure provided for in Article 58(2) of Regulation 2016/679, particularly merely issuing a reprimand (Article 58(2)(b)), would not be proportional to the identified irregularities in the personal data processing and would not guarantee that the Administrator would not commit further negligence in the future. Justifying the imposition of the maximum permissible administrative monetary penalty for entities in the public finance sector (100,000 PLN), it should be indicated that, in the opinion of the President of the UODO, a lower penalty would not fulfill its deterrent function, which is explicitly mentioned in Article 83(1) of Regulation 2016/679; it would also not discipline the Administrator to cooperate correctly with the President of the UODO in the future (as indicated below, the penalty imposed in this specific case also has a disciplinary and preventive character). At this point, it should be emphasized that one cannot speak of the severity of the penalty limited to the amount of 100,000 PLN, which is why imposing a penalty even at the maximum level of this threat does not constitute a harsh sanction. It is also worth noting that the amount of the imposed penalty results solely from the radical (in relation to the general monetary penalty threats provided for in the provisions of Regulation 2016/679) limitation of the threat provided for public entities in Article 102(1) of the Personal Data Protection Act. If the monetary penalty were imposed within the framework of the general threat specified in Article 83(5) of Regulation 2016/679 (without taking into account the limitation from Article 102(1) of the Personal Data Protection Act), the penalty imposed in this case – due to the significant weight and reprehensible nature of the violation (as indicated in the justification of the contested decision) – would have to be set at an amount many times exceeding 100,000 PLN. Under general principles, the maximum threat of a penalty for violating the principles regarding the processing of personal data specified in Article 5 of Regulation 2016/679 and Articles 6 and 9 of Regulation 2016/679 – in accordance with Article 83(5)(a) of Regulation 2016/679 – amounts to 20,000,000 EUR.

Referring to the amount of the administrative monetary penalty imposed on the Minister of Health, it should be noted that – given that the Administrator is an entity in the public finance sector, as referred to in Article 9(1) of the Act of August 27, 2009, on Public Finances (Journal of Laws of 2023, item 1270, as amended) – Article 102(1)(1) of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781) will apply, which results in a limitation of the amount (to 100,000 PLN) of the administrative monetary penalty that can be imposed on an entity in the public finance sector. In the opinion of the President of the UODO, the applied administrative monetary penalty fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it will be effective, proportional, and deterrent in this individual case.

In the opinion of the President of the UODO, the administrative monetary penalty imposed on the Minister of Health will be effective, as it will lead to a situation where the Administrator will implement such technical and organizational measures that ensure the processed data a level of security corresponding to the risk of infringement of the rights or freedoms of the individuals whose data are concerned and the severity of the threats associated with the processes of processing this personal data, and will also process data using the system [...] in accordance with the objectives defined in the Act on the Health Information System, which will simultaneously ensure the compliance of these actions with legal provisions. The effectiveness of this penalty is therefore equivalent to the guarantee that the Minister of Health, from the moment of the conclusion of this proceeding, will diligently adhere to the requirements set forth by the provisions on the protection of personal data.

The applied administrative monetary penalty is also proportional to the identified violation of the provisions of Regulation 2016/679, particularly its gravity, the negative impact on the person affected by the protection of personal data, and the high risk of negative consequences that, in connection with the violation consisting of a lack of technical and organizational measures adequate to the risk of processing personal data using the system [...], may be suffered by individuals whose data are processed in that system. In the opinion of the President of the UODO, the administrative monetary penalty imposed on the Minister of Health is not excessively burdensome for him, given the statutory

limitation on its amount in the case of entities in the public finance sector. In particular, its payment will not affect the Minister of Health's ability to fulfill his statutory duties. In the opinion of the President of the UODO, the Administrator should and is able to bear the consequences of his negligence in the area of data protection, hence the imposition of a penalty in the amount of 100,000 PLN (in words: one hundred thousand zlotys) is fully justified.

In the opinion of the President of the UODO, the administrative monetary penalty will serve, in these specific circumstances, both an educational and preventive function; in the opinion of the President of the UODO, it will indicate both to the Minister of Health and to other data administrators the reprehensibility of neglecting the obligations of administrators related to the occurrence of a personal data breach, as well as the responsibility of state authorities for unlawful actions taken by them using their power and capabilities, which...

****This authority grants.****

In the opinion of the President of the Personal Data Protection Office (UODO), the administrative monetary penalty applied meets, in the established circumstances of this case, the conditions referred to in Article 83(1) of Regulation 2016/679, due to the severity of the identified violations in the context of the fundamental requirements and principles of Regulation 2016/679 - especially the principle of lawfulness, fairness, and transparency, as well as the principle of integrity and confidentiality expressed in Article 5(1)(a) and (f) of Regulation 2016/679.

The purpose of the imposed penalty is to ensure compliance by the Minister of Health with the provisions of Regulation 2016/679 in the future.

In this factual and legal context, the President of the Personal Data Protection Office has decided as stated in the ruling.

[1] "Everyone has the right to respect for their private and family life, home, and communications."

[2] "1. Everyone has the right to the protection of personal data concerning them. 2. Such data must be processed fairly for specified purposes and with the consent of the data subject or on another legitimate basis provided for by law. Everyone has the right to access data concerning them and the right to have it rectified. 3. Compliance with these principles is subject to the control of an independent authority."

[3] The decision in English is available at:

https://edpb.europa.eu/system/files/2023-01/final_adoption_version_decision_wa_redacted_1.pdf

[4] Guidelines of the European Data Protection Board No. 9/2022, adopted on March 28, 2023.

[5] Act of April 23, 1964, Civil Code (Journal of Laws of 2023, item 1610, as amended)

Print article

****Metadata****

Provider: Department of Control and Violations

Information created by: Jan Nowak

2023-12-20

Information entered by:

Wioletta Golańska

2023-12-21 15:18:38

Last modified by:

Edyta Madziar

2024-01-31 13:58:14